

Identity & Access Model for Collation.AI

1. Identity Pools

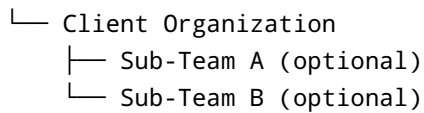
- **Internal Users** — anyone with @collation.ai email.
- **Client Users** — invited under a specific *ClientOrg ID* (one per RIA / family office).

2. Roles

Role Name	Holder	Scope of Access	Typical Actions
PlatformSuperAdmin	Internal	All client orgs — JIT-assumed, MFA required	Break-glass fixes, compliance exports, user provisioning
SupportEngineer	Internal	One client org at a time (time-boxed token)	Troubleshoot pipelines, view logs, rerun jobs
ImplementationEngineer	Internal	Assigned client org(s) during onboarding	Create connectors, seed data, migrate schemas
DataSteward	Internal (stable access)	Approved client org(s); long-lived assignment	Manual data entry, data-quality sweeps, remediation scripts
ClientOrgAdmin	Client	Whole client org & its sub-teams	Invite users, manage roles, approve data-sharing
DataEngineer	Client	Client org & chosen sub-teams	Build/modify pipelines, manage secrets
Analyst	Client	Client org & chosen sub-teams	Query data, build dashboards, export CSV
Viewer	Client or Internal auditor	Read-only as granted	View pipelines & data; no edits
ServiceAccount	Non-human	Least privilege per job	Headless execution of ETL / Airflow DAGs

A person may hold multiple roles; each session receives the **union** of privileges.

3. Client-Organization Structure



Data never crosses client-organization boundaries. Sub-teams are organisational only and inherit the parent boundary.

4. Data-Sharing Levels

1. **Private Workspace** – owner only
2. **Sub-Team Shared** – members of one sub-team
3. **Client-Org Shared** – everyone in the client organization
4. **Public to Collation** – explicitly flagged “share with support”

5. Enforcement & Guard-rails

Physical Segregation

- Each client org’s data lives in its **own database schema** and dedicated **SharePoint site**.
- Cross-org queries are technically impossible; network ACLs block inter-DB access.

Multi-Org Airflow

- Single Airflow instance; DAG folders namespaced `/clientorg-id/*`.
- Role-based folder ACLs enforced via Airflow RBAC & Kubernetes service accounts.

PII Controls

- Conservative definition: names, e-mails, phone numbers, account numbers, IPs, entity & portfolio names.
- Column-level AES-256 encryption; masking in UI unless user holds **DataEngineer** or higher.

Internal Access Discipline

- Support/Implementation roles assume per-org tokens (1–4 h).
- **DataSteward** assignments are long-lived but recorded in a grant ledger; auto-review every 90 days.

Audit Trail

- All read/write events written to append-only store partitioned by client org.
- Role and DataSteward-assignment changes push webhooks → Slack & SIEM.

Authentication & Branding

- Mandatory **client-side SSO** (OIDC/SAML) with group-to-role mapping.

- Whitelabel toggle loads client logo & colour palette at login time; URLs remain on `collation.ai` unless custom domain is contracted.

6. Rationale

Control / Change	Why it helps
DataSteward role	Grants stable yet scoped access for data hygiene without broad privileges, easing audits.
Hard physical segregation	Prevents accidental cross-org data leakage and reassures security-conscious clients.
Client SSO & whitelabel	Meets enterprise requirements for IdP control and branded user experience.
Detailed PII definition & masking	Aligns with SEC/FINRA guidance and privacy best practices.
Grant ledger & periodic reviews	Satisfies SOC 2 control CC6.3 for re-certifying privileged access.